Do You Play It by the Books?
A Study on Incident Response Playbooks and Influencing Factors

Daniel Schlette*, Philip Empl*, Marco Caselli†, Thomas Schreck‡, Günther Pernul*
*University of Regensburg, {firstname.lastname}@ur.de
†Siemens AG, marco.caselli@siemens.de
‡HM Munich University of Applied Sciences, thomas.schreck@hm.de

2024 IEEE Symposium on Security and Privacy (SP) | 979-8-3503-3130-1/24/$31.00 ©2024 IEEE | DOI: 10.1109/SP54263.2024.00060

***Abstract*—Incident response "playbooks" are structured sets of operational procedures organizations use to instruct humans or machines on performing countermeasures against cybersecurity threats. These playbooks generally combine information about a given threat and organizational aspects relevant within the context of an organization. Both types of information are crucial for using, maintaining, and sharing playbooks across organizations as they ensure effectiveness and confidentiality. While practitioners show great interest in playbooks, their characteristics have not yet been thoroughly investigated from a research perspective. For this reason, we explore the topic by analyzing what is inside a playbook. Our approach consists of a comprehensive empirical assessment of available data (1217 playbooks), an online study with 147 participants, and final in-depth interviews with nine security professionals to consolidate and validate our findings. We notably find intrinsic ambiguities in the way practitioners and organizations define their playbooks. Furthermore, we notice that available playbooks cannot be used outright which might currently impair their wide use across different cybersecurity actors. As a result, we can conclude that organizations do "play it by the books" but individually define what is inside their playbooks and which areas of incident response they might address.**

1. Introduction

Organizations facing cybersecurity threats should define and document standard operating procedures to ensure consistent cybersecurity operations and incident response [1], [2], [3], [4]. The shortage of skilled cybersecurity analysts [5], [6] draws additional attention to (automated) processes that can increase efficiency by reducing and eliminating errors. Integrating security tools, data, and teams is another pain point identified by cybersecurity practitioners [7], [8]. Dedicated processes can help organizations use resources effectively, particularly host and network tools, internal and external threat intelligence, and multiple security teams.

Playbooks represent processes and procedures which are part of every organization. In cybersecurity, more specifically in incident response and security operations, playbooks make for a novel field of research. While these playbooks address a specific threat or incident, they complement other well-established areas, such as system hardening [9], [10], vulnerability handling [11], [12], [13], [14], and business process management [15], [16]. System hardening, being mainly proactive, is based on checklists to fulfill generic security requirements (i.e., confidentiality, integrity, availability) during deployment. Vulnerability handling covers proactive scanning and security advisories where process representation (i.e., lists of remediations) is incomplete. Business process management and playbook-based IT operations (e.g., with Ansible [17]) show overlap but intentionally lack a clear cybersecurity focus. However, incident response playbooks address reactive scenarios, specifying what to do when things go wrong [18], [19].

With threats on the rise [20], there is a move toward playbooks as they promise consistency and automation. This development can be seen most clearly in the proliferation of Security Orchestration, Automation, and Response (SOAR) platforms [21], [22]. Playbooks are at the core of SOAR platforms that streamline security operations. Beyond vendors, standardization efforts and industry groups document the interest in playbooks and automation. The OASIS CACAO technical committee and the FIRST Automation special interest group aim to advance the representation of playbooks and explore user perspectives [23], [24]. As a result, playbooks are widely recognized, praised by professionals and playbook data has started to become available.

Nevertheless, open challenges around playbooks remain. Above all, we need to tackle the understanding of playbooks. Only a few previous works have discussed playbooks [18], [25], [26], [27]. Therefore, our work explores the overarching question: *What is inside a playbook?*

Initially, we observe the absence of an established theoretical playbook foundation. From an academic perspective, we suppose that playbooks are based on generic, technical information and contain additional organization-specific information. *Community playbooks*, describing generic operations and addressing existing threats, are stripped of any specific organizational context. They can be shared across different organizations as they do not convey confidential information. We expect to find these community playbooks analyzing repositories of different SOAR vendors.

When used within organizations, playbooks encompass additional organizational aspects defined by context. Making playbooks fit the context is about considering *influencing factors* and complementing community playbooks

© 2024, Daniel Schlette. Under license to IEEE.

DOI 10.1109/SP54263.2024.00060
Authorized licensed use limited to: IEEE Xplore. Downloaded on November 14,2026 at 05:10:50 UTC from IEEE Xplore. Restrictions apply.

with organization-specific information. An influencing factor (e.g., EU GDPR) may induce changes and makes a community playbook operational. We expect organizations that define incident response processes and use playbooks to point out influencing factors to some extent. While incident response playbooks are a novel research field, our theoretical considerations are relevant for organizations using, maintaining, and sharing playbooks.

Against this backdrop, we aim to validate our playbook hypothesis by exploring the following research questions:

RQ1: *What are characteristics of community playbooks made available by trusted sources?*

RQ2: *Which influencing factors shape incident response processes and organization-specific playbooks?*

To answer these questions we gather, preprocess, and analyze playbook data from leading SOAR vendors (e.g., Splunk), cybersecurity institutions (e.g., CISA), and open-source platforms (e.g., Shuffle). In our three-step approach, we further perform an online study ($n = 147$) and conduct interviews ($n = 9$) to deepen the discussion on playbook content with specific attention to influencing factors. In particular, this paper makes the following contributions:

- We introduce a theoretical foundation to the playbook concept. Considering community playbooks and influencing factors specific to an organization is crucial when using, maintaining, and sharing playbooks.
- We are the first to empirically analyze 1217 playbooks from 14 sources. Our analysis reveals that community playbooks are modular and contain a significant amount of information about tools and ticketing which are likely handled differently across organizations.
- We find that incident response processes and playbooks are indeed shaped by influencing factors but this is not necessarily recognized by practitioners. Our online study shows that the number of steps and the workflow inside a playbook varies. Interview participants mention specific implications of influencing factors.
- We report that while playbooks are well-known, understanding and use depend on implementation tools and abstraction levels.

The remainder of this paper is structured as follows. In Section 2, we outline playbook foundations. We describe our methodology and introduce a research model for influencing factors in Section 3. We report on the characteristics of community playbooks in Section 4. We present results form our online study in Section 5. Interview findings are reported in Section 6. We discuss the implications in Section 7. Section 8 presents related work before we conclude our work in Section 9.

2. Playbook Foundations

We define the playbook concept and show basic forms of playbooks representation. Influencing factors must be considered when sharing, maintaining, and using playbooks in organizations as they transform community playbooks.

TABLE 1. TEXTUAL, GRAPHICAL, OR CODE-BASED ELEMENTS AND NOTATIONS CAN BE USED FOR PLAYBOOK REPRESENTATION.

Type	Elements	Notation
Textual	Checklist, Table	Markdown
Graphical	Diagram	BPMN
Code	File, Script	JSON, Python

2.1. Playbook definition

Despite the growing interest, the notion of playbooks still needs to be clarified as other terms such as script, automation, runbook, checklist, standard operating procedure, workflow, or process are frequently used. Playbooks have been defined in a few other academic works [18], [28], [29], [30], [31], by cloud providers, and cybersecurity vendors. Most notable, according to the US President's Executive Order 14028, playbooks are "a standard set of operational procedures to be used in planning and conducting cybersecurity activity" [2]. Besides, standardization efforts (e.g., OASIS CACAO [23]) provide reliable information on playbooks and their components (see Appendix C for a detailed comparison of terminology and concepts).

In absence of an established incident response playbook definition, three characteristics guide our work: 1) *Security context.* Playbooks are used for cybersecurity purposes. 2) *Process representation.* Playbooks describe instructions to be followed. 3) *Technology integration.* Playbooks assist humans with technology and data. Upon these characteristics, a playbook to us describes a specific cybersecurity process or procedure based on a workflow with individual steps. Identified by [27], workflow steps are essentially actuator-action-artifact triplets describing who (e.g., firewall) performs an action (e.g., block) on an object (e.g., IP address). A playbook addresses a more or less specific threat or incident. We explicitly acknowledge different levels of abstraction found in playbooks.

2.2. Playbook representation

As playbooks represent processes and procedures, they logically structure information. Workflow steps can be structured sequentially, one after the other, or in parallel if the tasks and resources permit. Conditions can define the subsequent workflow steps. A text-based community phishing playbook might consist of the following steps:

- **Start:** Phishing email received
  - ☐ Create ticket and assign incident handler
  - ☐ Analyze email header, content and attachments
  - ☐ Correlate threat intelligence (DNS logs, IPs, hashes)
  - ☐ Search and remove (unread) phishing emails
  - ☐ Update protection systems and notify users
- **End:** Incident closed

Who the playbook is for – humans or machines – determines the decision for either textual, graphical, or code-based representation. The phishing playbook above

Authorized licensed use limited to: IEEE Xplore. Downloaded on November 14,2026 at 05:10:50 UTC from IEEE Xplore. Restrictions apply.

offers a generic human-readable description. Information is presented in text form with a checklist. Other playbook representations include graphical or code-based elements with different notations (see Table 1 and Appendix A, B). In the case of low-code/no-code SOAR platforms, human playbook designers construct graphical playbooks enriched with text and commands. The tools then generate and save a code-based representation for automation.

2.3. Playbook sharing, maintenance, and use

Inspired by collaborative cybersecurity and Cyber Threat Intelligence (CTI) sharing [29], [32], [33], we assume a basic setting as illustrated in Figure 1. Organization A (producer) shares community playbooks with Organization B (consumer). We expect that any organization-specific information is excluded as organizations value confidentiality. If Organization A is a SOAR vendor, playbooks are kept generic to promote widespread adoption of its platform.

On the receiving end, Organization B intends to use the playbooks for automation, onboarding, or other purposes. The playbooks' instructions contain essential elements (e.g., actions) that apply across organizations. However, the playbooks lack contextual elements of incident response specific to Organization B. For instance, Organization B might decide to sinkhole DNS traffic instead of blocking via firewall. Also, Organization B might only have a few incident handlers or outsourced services constraining in-depth malware analyses. Therefore, Organization B and other playbook consumers must transform playbooks to fit their context. The knowledge of influencing factors is a prerequisite for transforming and using community playbooks.

A push toward collaboration and actionable advice amplifies the relevance of playbook sharing. Industry groups (e.g., Financial Services Information Sharing and Analysis Center, FS-ISAC [34]) and (national) coordination teams can provide their constituents with playbooks. Sharing playbooks will help a small organization build incident response processes from the ground up. A large conglomerate can use playbooks to improve existing processes. Sharing can also aid in establishing a language to discuss incident response.

Influencing factors are also crucial for playbook maintenance within an organization. As organizations evolve, the organizational context changes. Consequently, knowing about influencing factors and how they manifest helps to keep organization-specific playbooks effective. For example, an organization might extend its business operations to another country with a different jurisdiction. As a result, changes in influencing factors (e.g., laws and regulations) require the transformation of existing playbooks by adding further reporting steps. The same applies when technology is discarded as threats and playbooks become obsolete.

2.4. Playbook transformation

Using and maintaining playbooks relies on two separate inputs: community playbooks and influencing factors. Via transformation, these inputs lead to organization-specific playbooks. Inputs might also be modified over time:

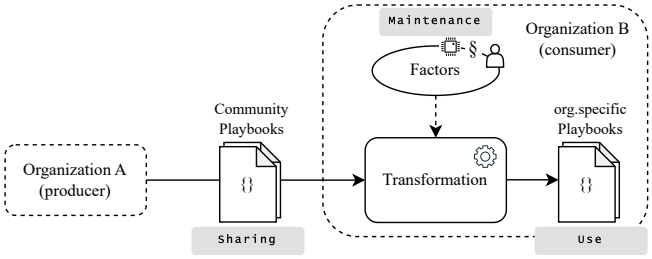


Figure 1. Sharing playbooks across organizations, maintenance, and use of playbooks put focus on influencing factors.

- *Modified community playbooks* reflect a changing threat landscape where new threats emerge. Community playbooks cover the various threats that demand countermeasures.
- *Modified influencing factors* reflect new organizational characteristics and external requirements. Influencing factors have organization-specific values and implications.

Our research, builds on these foundations and the study of "what is inside a playbook" focuses on analyzing community playbooks before examining how these are shaped by influencing factors.

3. Methodology

We follow a mixed-methods approach combining quantitative and qualitative research to thoroughly investigate playbooks. Playbook data is analyzed to answer the first research question on community playbooks. With our online study and qualitative interviews we aim to answer the second research question on influencing factors. Data collection for community playbooks, online study, and interviews was carried out between May 2022 and February 2023.

3.1. Playbook data

From an initial 1347 (18 sources), we empirically analyze 1217 community playbooks (14 sources) for their characteristics. After collecting the data, we opted to automatically preprocess and analyze the playbooks (leading to the exclusion of non-processable ones), making the playbooks and analysis transparent[1].

Data collection. We initially tried to collect playbooks from all major SOAR vendors based on two popular market reports [21], [22]. Thus, we acquired access through GitHub repositories, engaged in a demonstration, or implemented the software through local deployment. However, we faced different obstacles. In particular, playbooks from several vendors were not publicly accessible, our requests remained

1. https://github.com/luduslibrum/awesome-playbooks

Authorized licensed use limited to: IEEE Xplore. Downloaded on November 14,2026 at 05:10:50 UTC from IEEE Xplore. Restrictions apply.

unanswered, or vendors demanded non-disclosure agreements. To prevent any potential negative impact upon these vendors, explicit mention of their identities is deliberately withheld. To the best of our knowledge, we are the first to collect and compile a comprehensive playbook repository.

Data preprocessing. Using Python, we built custom connectors for each vendor to create schemata and extract relevant data from the heterogeneous playbooks. In addition, we used Jupyter notebooks to review and label 8,623 machine-generated actuator-action-artifact triplets. By extracting triplets, we can categorize each playbook step.

Data analysis. Jupyter notebooks also describe our data analysis. We use NLP stemming, tokenization, and dependency parsing to extract the actuator-action-artifacts triplets based on the step name. We tested different clustering methods (e.g., k-Means, based on text vectorization and PCA) to identify step categories and also tried topic modeling methods. However, the methods remained unsuccessful mainly because the clusters or topics were ambiguous. We noticed that step names are not distinctive, e.g., "investigate" or "block IP address" are two different topics, and observed that vendors use different vocabularies to describe their steps. This leads us to manually label 370 unique actions to identify the categories.

3.2. Research model and rationale

Extending the scope of our research to organization-specific playbooks, we set up a research model (see Figure 2). The model divides influencing factors in two groups – external and internal factors – and is used for our online study and interviews. Influenced by factors, incident response processes and playbooks are characterized by workflow logic and the content of individual steps. For groups and factors, we borrow from information security policy research [35], [36] and business process literature [37], [38].

We presented our idea of influencing factors at a major industry conference for incident response teams. When asked via interactive poll, all participants agreed that factors do influence incident response. However, answers started to vary when pressed, which is the most important factor. The feedback we received points to legal aspects, people, and technology. While organizations must determine if they can perform incident response processes as envisioned, they are also influenced by staff and available systems.

External factors. We assume attacker characteristics, including motivation, behavior, location, and others, to affect processes. Industry standards and guidelines, such as frameworks, can constitute an external factor as they serve as process references. In addition, laws and regulations require organizations to conduct incident response and implement compliant processes. These legal aspects capture, for example, business structure, location, and sector. We further assume that business partners and other organizations within the supply chain formulate expectations influencing organizational processes. Factor → impact examples are:

- Sophisticated attacker → long-term monitoring
- ISO/IEC 2700x → evidence collection
- EU GDPR → informing supervisory authorities
- Outsourced services → contact external team

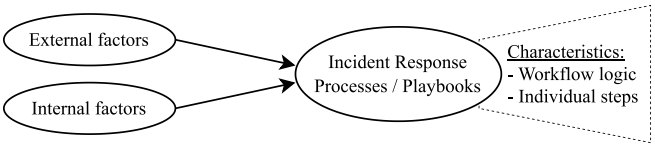


Figure 2. Theoretical research model with two factor groups influencing incident response processes and playbook use.

Internal factors. Organizations can choose to abide by arbitrary internal rules or directives. Such internal factors can center on incident response data operations and attack targets. Besides, people form another internal factor which encompasses security culture and various security team-related elements (e.g., team size, chain of command, and responsibilities). The technology, general and cybersecurity specific, within an organization provides a setting in which incident response processes are placed. Thus, IT infrastructure and security tools might also explain variations in incident response processes. Factor → impact examples are:

- CRUD constraints → no data copying
- CTI team → CTI sharing
- Security automation tools → querying endpoint agents

Observable differences. Discussing influencing factors directs attention to their observable influence on processes. We identify three possible changes caused by influencing factors – the first two center on workflow logic and the last on step semantics. We anticipate that incident response processes and playbooks can differ across organizations in the *number of steps*. Influencing factors might lead to more or fewer process steps changing workflow logic. Besides, we account for *sequential or parallel workflow*. Factors can introduce conditions to guide process flow, and process steps might be aligned sequentially or in parallel. Last, influencing factors can cause the actuator-action-artifact triplet to change, while the number of steps remains the same (*altered steps*).

3.3. Online study

The primary objective of the online study is to assess the relevance of influencing factors within organizations. Therefore, we collected data from 147 participants reaching a broad audience within incident response. One of our co-authors with experience in online research methodology, provided expert guidance throughout our iterative process. To assess the validity and reliability of our questionnaire, we administered it to a group of colleagues in a controlled setting. In our questionnaire (available at our GitHub repository[2]) we first provide contextual cues pertaining to the authors' affiliations and the scientific nature of the study, while also emphasizing the voluntarily participation. Furthermore, participants are instructed to consider their responses within

2. https://github.com/luduslibrum/awesome-playbooks/tree/main/factors

Authorized licensed use limited to: IEEE Xplore. Downloaded on November 14,2026 at 05:10:50 UTC from IEEE Xplore. Restrictions apply.

the context of their respective organizations. Among other background questions, we directly ask for influencing factors (in three incident scenarios) and beliefs thereof. We have extra questions exclusively for participants using playbooks which $\approx 85\%$ do.

Participant recruitment and data. We recruit participants using our professional networks. We ask for participation via email, social media (i.e., LinkedIn), and industry groups (i.e., FIRST). Participants currently employed in cybersecurity are requested seven minutes of their time to partake. As it is difficult to get participants' time, we provide a monetary lottery incentive (100€) with a 1:147 chance if they participate within the next 15 days. Facing unsolicited responses ($\approx 90\%$), we completely exclude any observations which contain invalid (i.e., non-English), redundant, and implausible answers. Exclusion is mainly based on free text fields (e.g., What is a playbook to you?) indicating missing security context (e.g., stage play) and numerical values. Further, redundant observations within a few-minute threshold containing only partial variations are excluded. In order to prevent the participation of bots, we included a math CAPTCHA as a security measure. We used the statistical software Stata to analyze the data.

3.4. Interviews

We interviewed security professionals working on incident response topics to gain deeper insights into influencing factors. While data saturation is arguable, we ceased the interview process after nine interviews as the results showed only marginal additions. The interviews were semi-structured to allow for flexibility and open-ended questions. Participants were not made aware of our research questions and instead asked about the effect of influencing factors in specific "what-if" scenarios. We opted for questions on incident response processes and procedures to remain unbiased of playbook notions. However, we actively asked additional questions whether and how participants use playbooks.

Interview guide. Following a pretest (with two colleagues working in incident response 5+ years), the interview questions were adapted and reviewed by all authors. Our interview guide consists of four parts: 1) *Demographics.* We ask about a participant's role and organizational characteristics. 2) *Incident response basics.* We ask about incident response within a participant's organization. 3) *Incident response scenarios.* We outline three incidents (Ransomware, DDoS, APT) and ask about a participant's organizational processes and implications of specific influencing factors. 4) *Playbooks.* We ask about playbook understanding and use.

Interview procedure. We conducted the interviews using cognitive interviewing methodology [39]. Interviews were held in German or English virtually via Zoom (invites send by email), except for one in-person meeting. At the outset of the interviews, we introduced the topic, emphasizing the significance and relevance of the interview, and highlighting the research methods to collect and evaluate the data. Participants consented that notes were taken during the interviews. We further asked the participants if we could use their answers in anonymous or aggregated form for scientific publication, to which participants agreed. The interviews lasted from one hour to one hour and thirty minutes.

Participant recruitment. Participants working on incident response topics were selected based on personal contacts and the authors' professional networks reflecting industry experience. Most interview participants work for large (> 5000 employees), multi-national corporations headquartered in Germany. Asked about how they would rate the maturity level for cybersecurity in their organization, most participants mentioned a high maturity compared to peers.

Coding and analysis. Interview questions and transcribed interview data are associated with influencing factors during data coding by two coders. We use thematic analysis [40], [41], [42] and corresponding deductive/inductive coding to relate questions and answers to themes (see Appendix E). Our themes are based on the research model with its influencing factors (Section 3.2). Conflicts (e.g., supply chain and laws) are resolved with re-reading and team discussions.

3.5. Ethics

Cybersecurity incidents and organizational processes are delicate topics. We validated our research approach with our institutions' ethics committees via email, explaining our research and data handling. We got confirmed that there is no legal obligation to obtain an ethics vote as very limited personal data is handled. While we were met with great openness, we aim to assure the anonymity of our study participants. Our questionnaire consisted of 43 questions, of which we left 37 open-ended. Participants gave their consent and had the option to opt-out at any point during the process. We deliberately refrained from participant monitoring (e.g., drop-outs, completion time) for privacy reasons. Notification was only provided to the winner of the lottery incentive, via email, while the rest remained unnoticed. We contacted potential interviewees twice, via email, after an initial contact attempt. We collected only a limited amount of demographic information, report mostly aggregated data, and in order to minimize errors, we allowed each interview participant to check and correct their quotes. We did not require non-disclosure agreements from any of our participants.

3.6. Limitations

While our study provides valuable insights, it is important to acknowledge its limitations, particularly with regard to the *playbook data*: The playbook data we analyze is mostly code-based, includes only a selection of vendors mentioned in two SOAR market reports, and is not representative of all platforms. This limits the scope of our analysis. Given the rapid pace of technological advancements and market consolidation, the community playbooks collected could become outdated fast. Another challenge we faced was the poor data quality in the community playbooks. The actuator-action-artifact triplets often contain

Authorized licensed use limited to: IEEE Xplore. Downloaded on November 14,2026 at 05:10:50 UTC from IEEE Xplore. Restrictions apply.

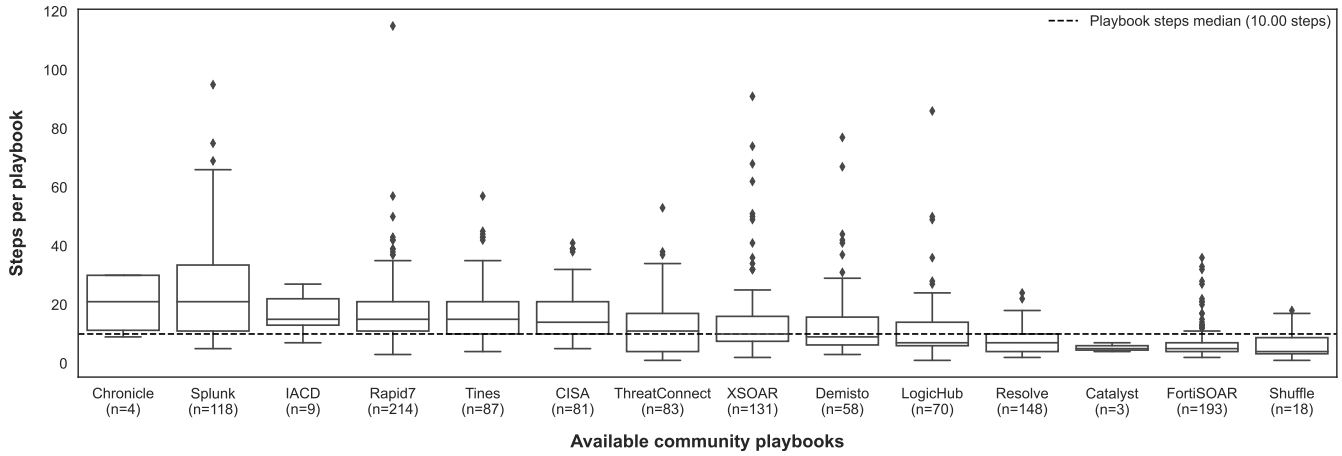


Figure 3. Exploring the characteristics of 1217 playbooks based on the number of steps.

typos, programming syntax, or incomplete data, making it almost impossible to analyze the data using clustering and topic modeling techniques. Although the step categories are highly specific, their contents can overlap due to blurry task boundaries (e.g., append or update data), The situation requires manual labeling of triplets, which can be prone to errors. We encountered ambiguity in labeling steps, often requiring us to assign them to multiple categories, e.g, the action "check" could be part of an investigation but also a logical gateway. In the *user study*, there could be potential biases and undetected duplicates related to the financial motivations of the participants, which may have influenced their responses. This may limit the reliability of our findings. Lastly, for the *interviews*, we faced challenges in identifying and accessing incident response professionals, making it difficult to obtain a representative sample.

4. Community Playbook Analysis

This section targets RQ1 and investigates the structure and content of community playbooks (see Figure 3 and Table 2), thereby partly confirming existing theories [18], [27]. We present our findings of community playbook characteristics at playbook and workflow step level. Moreover, we categorize steps and show multi-category playbooks.

4.1. Playbook level

Playbooks exhibit high structural homogeneity across vendors, with variances predominantly found in their implementation-specific nuances. Below we summarize the components of an incident response playbook:

Meta information Descriptive elements, including an identifier, name, description, and categorization tags, serve to identify, retrieve, and understand a playbook. Playbooks also comprise specific details on attributes such as visibility, ownership, inheritance, or versioning.

Workflow At the core of a playbook lies the workflow. The workflow denotes a security process's systematic and logical sequencing, characterized by a discrete set of individual steps discussed in more detail in Section 4.2.

Parameter Playbooks receive input and produce output. Inputs, outputs and other environmental parameters (i.e., playbook variables) can be defined globally at the playbook or workflow step levels.

Features As features, we define all playbook components that were used only occasionally. Such features encompass deployment specifications, playbook validation, testing procedures, process visualization, sharing policies, return on investment, or priority handling.

Community playbooks are mostly code-based and predominantly represented by JSON, YAML, and XML, with some sources opting for alternative tabular or graphical approaches in Business Process Modeling Notation (BPMN) [43]. There is a discernible inclination towards modularity to support community playbooks' reusability. For example, some vendors rely on playbook hierarchies to allow "playbooks calling playbooks" and their unrestricted reusability across individual use cases. These use cases leverage the logical linking of community playbooks. We find malware playbooks confirming this modularity. While one malware playbook is solely responsible for email notifications, the other handles malware hunting, and containment. We also find playbooks that include and test vendors' platform integrations, e.g., testing the connection to Microsoft Teams.

4.2. Workflow step level

The workflow establishes a coherent sequence of steps. Each step comprises meta-information, including an identifier, a name, and a description. Moreover, a workflow step encapsulates the underlying logic, which guides the orchestration of the workflow. Notably, every workflow step contains an actuator-action-artifact triplet.

Authorized licensed use limited to: IEEE Xplore. Downloaded on November 14,2026 at 05:10:50 UTC from IEEE Xplore. Restrictions apply.

TABLE 2. WORKFLOW STEP CATEGORIES, THEIR FREQUENCIES AND ILLUSTRATIVE ACTUATORS, ACTIONS, AND ARTIFACTS.

Category	Frequency (abs./rel.)	Actuator	Action	Artifact
Logic	3,770 (*22.5%*)	Platform, human, API	trigger, loop, decide	Playbook, while, condition
Utility	3,834 (*22.8%*)	Platform, JMESPath, JoinArray	extract, filter, format	Status, data, report
Ticketing	2,344 (*13.9%*)	Microsoft Teams, Slack, Jira	send, document, close	Email, ticket, case
Investigation	5,943 (*35.3%*)	Human, VirusTotal, HashIt	link, search, lookup	Indicator (IP, domain/URL, file/hash)
Countermeasure	930 (*5.5%*)	AD, firewall, endpoint protection	block, quarantine, reset	Indicator, user, endpoint

Workflows differ in their complexity and scope. Figure 3 compares community playbooks, indicating a median of 10 steps and a mean of 13.78 steps per playbook. We calculated the step size based on the respective array length of the workflow. However, the number of steps varies depending on the source, with 25% of the playbooks possessing less than six or more than 17 steps. Notably, a crucial aspect of SOAR is the automation of workflows, which is reflected in the degree of automation of the workflow steps. On average, 96.93% of the steps in the workflows are automated, whereas the remaining 3.07% of the steps necessitate human interaction. The rationale for human interaction stems from the workflow step type involved.

Workflow steps vary in their type. Based on 16,821 workflow steps, we identify seven types: start/end, single, decisions, loop, trigger, information, and playbook, confirming the CACAO [23] notion except for a parallel workflow step type. The start and end step types demarcate the scope of the playbook. More than half of the workflow steps are single, encompassing security operations, including HTTP requests, filtering, and transformation tasks. Workflow steps orient on well-known process gateways, such as decisions or loops. Decisions are made automatically via conditions or manually via ChatOps, prompts, and workflow interactions. Loops either wait for conditions to finish or conduct actions for each element in a list or array. Another type of workflow step comprises triggers that await a specific event. Informational workflow steps are also pertinent for informing humans, as they provide details about the current status or display relevant data. Lastly, certain workflow step types call other playbooks.

Accurately distinguishing between step types is challenging as some sources have integrated the process flow directly into each step. This means each step knows the predecessors and subsequent steps, including loops and conditions. Contrarily, other sources define the process flow globally in the community playbook, related to a node-link diagram. These varying approaches have far-reaching implications for the playbook's readability, length, number of steps, and step types. Another interesting aspect concerns how vendors integrate applications into their SOAR platform, including native integrations with their custom adapters or direct API calls to the application. Last but not least, from the total of 16,821 workflow steps, we identified 8,623 (51.3%) unique workflow steps indicating the reuse of steps within playbooks.

4.3. Categorization

We manually label unique workflow steps using the actuator, action, and artifact information and assign a specific category to a workflow step. We sometimes assign multiple step categories to a particular workflow step due to ambiguities. In these cases, a workflow step is related to multiple categories. Our findings on step categories are summarized in Table 2 and explained below.

Logic includes all the elements that play a crucial role in organizing and maintaining the process flow. The platform and the human are the primary actuators responsible for this category. For example, the security analyst decides the subsequent process path(s), calls additional playbooks, or initiates further workflow steps.

Utility encompasses all operations that are ancillary to the workflow's logic but crucial for supporting the other step categories. For instance, the platform utilizes regular expressions to extract data from a report.

Ticketing or alerting refers to the incident or case management to initiate a case and inform relevant stakeholders. A workflow step within this category may subsequently be reapplied to update a ticket.

Investigation deals with the search and analysis of relevant threat information, i.e., tactics, techniques, and procedures (TTP). A case in point would be a security analyst scrutinizing a phishing email, identifying an unfamiliar domain, examining its geographic location, and classifying it as an indicator of compromise.

Countermeasures go beyond analysis and take measures to counteract a threat through remediation, containment, and recovery. For instance, the security analyst mentioned in the previous example would block the IP address or domain of the phishing email.

Multi-category playbooks. As playbooks often comprise multiple step categories (e.g., logic steps are commonly integrated into workflows), it is imperative to investigate the composition of playbooks based on their step categories.

We present the composition of multi-category playbooks and show the likelihood of encountering a particular step category within a playbook of n categories (see Appendix D Figure 4). To arrive at these findings, we analyzed playbooks containing at least two categories, accounting for 91.4% of the total playbooks. On average, playbooks mainly comprise logic and utility steps, with varying degrees of alerting/ticketing, investigation, and countermeasure steps. Besides, 7.2% of the playbooks feature all step categories, whereby the likelihood of encountering investigation steps

Authorized licensed use limited to: IEEE Xplore. Downloaded on November 14,2026 at 05:10:50 UTC from IEEE Xplore. Restrictions apply.

TABLE 3. ONLINE STUDY PARTICIPANTS AND THEIR BELIEFS ON INFLUENCING FACTORS

Continent ($n = 144$)			
EMEA	84 (58.3%)	Asia	13 (9.1%)
America	47 (32.6%)		
Sector ($n = 141$)			
IT	74 (52.5%)	Industrials	13 (9.2%)
Public	21 (14.9%)	Consumer	7 (5%)
Financials	16 (11.3%)	Other	10 (7.1%)
Role ($n = 147$)			
Sen. sec. manager	58 (39.5%)	IT operations	11 (7.5%)
Sen. sec. expert	20 (13.4%)	Sec. researcher	11 (7.5%)
Sec. operations	15 (10.2%)	Sec. consultant	11 (7.5%)
Incident handler	15 (10.2%)	Other	6 (4.1%)
Influencing factors ($n = 142$)			
Technology	112 (78.9%)	Laws & regul.	74 (52.1%)
IR directives	98 (69%)	Attacker charact.	71 (50%)
People	94 (66.2%)	Supply chain	46 (32.4%)
Industry stand.	79 (55.6%)		

within these playbooks is 34%. However, most playbooks have three different categories and the majority of these does not include countermeasure steps instead focusing on investigation (e.g., sighting inactive users or reviewing indicator reputations).

Additionally, we investigate whether playbooks consisting of five categories are intentionally designed for a specific incident type (e.g., malware or phishing). Upon analysis of 82 playbooks, we often find varying purposes, but also playbooks aligned to incident types. We derive that if a countermeasure step is included, there are likely ticketing and investigation steps in advance. This observation may account for the increased likelihood of countermeasures when more playbook categories are involved. Across all 1217 playbooks, we found 50 phishing (4.1%) and 27 malware (2.2%) playbooks.

4.4. Implications for playbook adoption

Our results show that community playbooks are predominantly generic but contain organization-specific aspects. Workflow steps cover handling alerts and ticketing, which likely vary by organization. Meeting compliance requirements by adhering to service level agreements (SLAs) is present in community playbooks but must be determined in an organizational context. Further, community playbooks include people, technology, and best practices, but their adoption and use can vary significantly from organization to organization. For example, an organization may rely on a single analyst managing tickets or use divergent technologies, such as firewalls or communication tools, not integrated into vendor offerings. Ultimately, community playbooks are designed to match the vendors' product portfolios and focus on the vendors' customers as best as possible, not necessarily addressing the broad incident response community. Therefore, tailoring community playbooks to the organization's context is crucial to cater to the diverse needs (e.g., beyond automation) of different organizations. In the following sections, we will delve into the organizational context to better understand the factors that influence the transformation of community playbooks into organization-specific playbooks.

TABLE 4. ONLINE STUDY PARTICIPANTS AND THEIR ORGANIZATIONAL PLAYBOOKS.

	Mean (Std.)	Median	n
Employees	35,756 (120,871)	600	145
Experience [years]	9.8 (6.5)	8	143
Security teams	2.9 (1.79)	3	142
IR team size	20.5 (36.2)	7	136
Team maturity [0-4]	2.7 (1.1)	3	145
Process maturity [0-4]	2.7 (0.9)	3	144
Tech. maturity [0-4]	2.7 (1.0)	3	144
Playbook contribution [0-4]	2.5 (1.25)	3	124
Org. playbooks	24.5 (46.8)	9	125
Malware steps	10.2 (7.9)	7	108
Phishing steps	8.4 (7.1)	6	102
Account comp. steps	8.6 (6.7)	9	100

5. Online Study Results

In this section, we address RQ2 and employ an online study to first investigate the relevance and impact of the influencing factors responsible for the transformation of community playbooks. We report the findings of our online study, which included a sample of $n = 147$ participants. The data is presented in Table 3 and Table 4 for better clarity. First, we provide an overview of the participants' demographics and their respective organizations, including incident response capabilities. Subsequently, we investigate the prevalence of playbook sharing, use, and maintenance in the surveyed organizations. Additionally, we explore the differences between malware, phishing, and account compromise playbooks within these organizations, with participants indicating the number of steps required for each playbook. Finally, we detail how the participants perceive the significance of influencing factors.

Playbook understanding. The study primarily consists of participants from Europe, the Middle East, and Africa (EMEA). Most participants are associated with the information technology (IT) sector, occupying senior positions like security managers, including SOC and CTI managers. On average, the surveyed organizations have three security teams in place, namely, incident response (CERT/CSIRT), threat intelligence, and security operations center (SOC). An incident response team, on average, comprises seven employees. All participants report that their organizations possess mature people, processes, and technologies for incident response. The term "playbook" is predominantly used by most participants, while some mention related terms like "runbook/workflow" (an automated playbook), "stories" (use cases), "standard operating procedure", or "incident management framework". This indicates a partial variance in the participants' perception of playbooks. The majority of respondents mention an active involvement in the playbook design. On average, an organization has 24.5 playbooks, with a high standard deviation indicating stark differences.

Authorized licensed use limited to: IEEE Xplore. Downloaded on November 14,2026 at 05:10:50 UTC from IEEE Xplore. Restrictions apply.

Playbook use. According to the participants, the primary reasons for using playbooks are documentation (79.7%), automation (52.8%), compliance (51.2%), and onboarding (44.7%). The majority of playbooks are text-based (76.7%), followed by graphical (46.8%) or code-based (38.7%), which highlights the significance of documentation. In terms of operational use cases, playbooks are primarily utilized for investigation/analysis (83.6%), countermeasures/mitigation (68.9%), and alerting/ticketing (60.7%). About 52.5% of respondents use playbook hierarchies also seen in community playbooks. Regarding the relevance of the aforementioned use cases, 40% of respondents indicate using external playbooks, all of which have been modified for organizational context. Moreover, 71.1% of respondents share playbooks internally, while 13.2% also share them externally.

Playbook differences. We analyze the differences between organization-specific incident-type processes or playbooks. Therefore, we asked the participants about their malware, phishing, and account compromise workflow characteristics: step count, parallel steps, and involved influencing factors. On average, 67% of respondents report that their incident-type playbooks include parallel steps. Conversely, this indicates that these playbooks can be logically distinguished from other playbooks. Regarding the number of steps, we observe a high standard deviation ($\pm$ seven steps) in all kinds of playbooks. Malware playbooks contain the most steps on average compared to the other two, while the account compromise playbook has the highest median. All in all, we see a varying number of steps in the individual playbooks, which we attribute to the influence of factors.

Influencing factors vs. beliefs. Specifically, we asked participants to identify factors affecting incident response processes and whether their incident-type playbooks include steps that reflect these factors. The participants believe that technology is the most crucial factor, followed by incident response directives and people. This implies that technological advancements within an organization are seen to have an impact on incident response processes and playbooks. Incident response directives and the security team(s) also play a crucial role. In the case of malware incidents, technology remains the most significant factor, followed by incident response directives and attacker characteristics. Similarly, phishing playbooks are influenced most by technology, incident response directives, and the security team. Last, in the case of account compromise, attacker characteristics are stated as the most relevant factor, followed by technology and team. In all three scenarios, it is noticeable that the characteristics of the attacker are important, although the participants believe that they generally play a relatively minor role. This means that organizations strive to identify the attacker's motivation, particularly regarding account compromise. In general, we observe that different influencing factors shape incident response processes and playbooks.

To sum up, our observations indicate that organizations have specific playbooks indicated by step count, parallel workflow and factors. They commonly use them to document organizational security processes. Playbooks are also frequently shared and modified. We can not derive which factor influences playbooks the most as it strongly depends on the use case. However, technology, incident response directives, people, and attacker characteristics seem to be prevalent. It remains unanswered which influence a factor exerts on community playbooks. Therefore, our interviews with incident response professionals go into detail.

TABLE 5. INTERVIEW PARTICIPANTS ARE CHARACTERIZED BY INDUSTRY SECTOR, POSITION, AND ID.

Sector	Position	ID
Information Technology	Tech / Mgmt	P3, P6, P7
Industrials / Materials / Energy	Tech / Mgmt	P2, P4, P8, P9
Public Institution	Tech	P1, P5

[Tech] technical positions [Mgmt] management positions

6. Interview Findings

This section validates and complements Section 5 with in-depth discussions of influencing factors through interviews. We describe for each external and internal factor the (missing) influence on incident response processes and playbooks. Table 5 presents details about the participants and their ID. Influencing factors and selected statements made by interview participants are listed in Table 6. The findings below depict aggregated data from the interviews.

Processes and playbooks are organization-specific. We had interview participants elaborate on their organization's incident response processes and playbooks. They offered detailed insights into what they do and what others might not be doing (e.g., investigations, CTI sharing, or coordination). Mostly, processes and playbooks are generic and aligned to incident types (e.g., phishing, malware, or account/system compromise) or recurring events. We can report that all interview participants were aware of playbooks or used playbooks as *"they can reduce time spent on tasks, improve task quality, and allow rookie teams to have stable operations." (P8)* Whether processes and playbooks are organization-specific, participant P3 sums up a common stance: *"The incident response team creates playbooks [...]. [Community playbooks] never fit the organizational context and are either too generic or too specific for certain products." (P3)* Combined with other participants' statements this leads us to conclude that organizational context and factors matter. In community playbooks, we find domain (e.g., ICS), vulnerability (e.g., 8×Log4J and 5×WannaCry), and generic playbooks.

Attacker behavior and motivation beat location. Behind every attack or incident, there is a threat actor. Organizations fending off attacks and coping with incidents take attacker characteristics into account. However, interview participants paint a nuanced picture when asked about the influence of more specific attacker characteristics, such as presumed location, behavior, and motivation, on their processes. Unintuitively, precise attribution, whether attacks originate from a specific group and country, is considered

Authorized licensed use limited to: IEEE Xplore. Downloaded on November 14,2026 at 05:10:50 UTC from IEEE Xplore. Restrictions apply.

TABLE 6. INFLUENCING FACTORS AND STATEMENTS MADE BY INTERVIEWED PROFESSIONALS.

	Influencing Factor	Participant statement
External	Attacker characteristics	"We investigate for longer when we think there is more to know [in the case of an APT]." (P4)
	Industry standards	"We started with ISO 27035 and developed a [high-level] process according to our organizational needs." (P8)
	Laws and regulations	"Playbooks and actions are pre-approved by legal. We keep lawyers in the loop [during incident response]." (P7)
	Business structure	"We have a general [workflow] step to check if authorities need to be informed." (P4)
	Location	"We perform EU GDPR assessment and inform authorities." (P2)
	Sector	"Only incident handlers in the US are allowed to handle incidents affecting US military contracts." (P3)
	Supply chain	"We collaborate with an ISP [for DoS attacks]." (P1)
Internal	Incident response directives	"Playbooks go into detail. A step refers to 'investigate headers' and which specific tools to be used." (P7)
	Data operations	"We manually extend data retention adapting the log settings [in the case of an incident]." (P1)
	Targets	"We have a crisis mode, a dedicated crisis team, and retainers with [...] forensic companies." (P3)
	People	"We do shift operations, on-call duty, and follow the sun for incident response." (P9)
	Security culture	"Permissions and pre-authorizations are important. At times you have to act without [explicit] permission." (P2)
	Security team	"We diligently share information, insert data in MISP, and correlate incidents." (P4)
	Technology	"Business units or third parties operate our infrastructure. We advise and coordinate measures." (P6)
	IT infrastructure	"If necessary, we integrate third parties (AWS, Microsoft) into our process. They are notified by email." (P9)
	Security tools	"Without a [SIEM/SOAR] dashboard, we rely on [administration] tools to detect and respond to incidents." (P5)

less relevant as *"clarifying attack origin is clearly not the duty of private corporations but should be delegated to law enforcement." (P2)* This is contrasted by 16 "geolocate IP address" steps in community playbooks.

As explained by participants' narrow understanding of attribution as solely identifying the attacker's location, *"it is all about technical matters rather than where the attack originated from." (P6)* Consequently, the focus is shifted to the influence of attacker behavior and motivations. Beyond prioritization, security teams escalate to management and conduct additional threat hunting in an Advanced Persistent Threat (APT) scenario. Community playbooks also prioritize alerts, incidents, and users, but do not address APTs. Different motivations (e.g., espionage, financial gain, or reputation) are reflected in decisions to observe or eliminate threats: *"We investigate for longer when we think there is more to know [in the case of an APT]." (P4)*

Industry standards provide broad guidance only. Organizations build on industry standards and guidelines for their high-level incident response process. Overarching frameworks (e.g., NIST Cybersecurity Framework, Incident Response Life Cycle, or FIRST CSIRT framework) are often adapted: *"We started with ISO 27035 and developed a [high-level] process according to our organizational needs." (P8)* This finding is replicated by community playbooks containing 45 steps aligned to the MITRE ATT&CK framework and CISA's playbooks being primarily based on NIST SP 800-61. On a more detailed level addressed by playbooks and automation scripts, we cannot infer any influence of industry standards and guidelines from the interviews.

Laws and regulations apply throughout. A central finding in our validation was the relevance of legal aspects for incident response. In our interviews, participant P7 summarized the influence of laws and regulations on processes at different levels: *"Playbooks and actions are pre-approved by [our] legal [department]. We keep lawyers in the loop [during incident response]." (P7)* We conclude that any initial process design and playbook transformation must consider legal influences. Defined roles and communication between security and legal teams can help streamline security processes, especially in unfamiliar situations.

When examining the influence of more specific legal aspects, we make the following observations:

- Business structure requires compliance, but the influence is vague: *"We have a general [workflow] step to check if authorities need to be informed." (P4)*
- Location-based influence is mainly about privacy and data protection: *"We perform EU GDPR assessment and inform authorities." (P2)*
- Sector-based influence, most notable in the defense industry, has implications on security operations: *"Only incident handlers in the US are allowed to handle incidents affecting US military contracts. We do reassign responsibilities accordingly." (P3)*

Overall, there is a strong emphasis among participants that technical incident response is separate from legal processes. For instance, while we expected to hear about SEC 8-K filings for NYSE-listed corporations or regional equivalent regulations, our participants from large organizations instead delegated responsibilities. Nevertheless, participants indicated the relevance of organizational aspects in their processes: *"Our legal department gets [corresponding] tickets in their ticketing system when [a GDPR-related] incident happens." (P7)* Beyond Europe, a legal influence was mentioned for the USA but not for other countries: *"If the US is concerned, we have separate procedures." (P4)* In community playbooks, we do not find specific laws and regulations.

When in doubt, collaborate with business partners. Recent attacks and proposed legislation (e.g., EU Cyber Resilience Act) put focus on cybersecurity within the supply chain. However, we do not see a clear indication of the influence of business partners' expectations on specific processes within the interview results. We note that most participants

Authorized licensed use limited to: IEEE Xplore. Downloaded on November 14,2026 at 05:10:50 UTC from IEEE Xplore. Restrictions apply.

work for larger organizations which, whenever necessary, collaborate with other organizations to resolve incidents: *"We collaborate with an [Internet Service Provider,] ISP [for DoS attacks]." (P1)* Another explanation for missing influence is the overlap with other factors, such as laws and regulations or internal technology sourcing strategies. Community playbooks feature sharing indicators with partners via dedicated platforms (e.g., MISP), reporting malware samples, and notifying security vendors.

Besides external influencing factors, we evaluate internal factors shaping incident response processes and playbooks.

Directives address the finer points of incident response. Organizations have flexibility in how to handle incidents. Thus, individual workflow steps and actions can contain precise instructions permitting or constraining specific data operations (e.g., data copying) and addressing specific attack targets (e.g., devices of board members). Our interview participants mention SLAs that define incident response. For instance, when to start working on a case or report to management, but there is no definite time to close a case. On a technical level, tool selection is covered: *"Playbooks go into detail. A [workflow] step [within a phishing playbook] refers to 'investigate headers' and which specific tools to be used." (P7)* Beyond these observations, we find:

- When organizations have to deal with storage constraints they perform additional data operations: *"We manually extend data retention adapting the log settings [in the case of an incident]." (P1)* This is partially contrasted by large organizations that have nearly "unlimited" storage capacity: *"We aim for storing logs for a year. The more data, the better." (P4)* Nevertheless, costs are considered.
- Organizations adapt incident response when attack targets are business critical (e.g., systems or accounts). We note that these situations require a special process, are handled with priority, or are taken "off-process". As a result, precautions are taken: *"We have a crisis mode, a dedicated crisis team, and retainers with incident response and forensic companies." (P3)* Additionally, access to information might be restricted. Some participants object that incident response is always on a need-to-know basis, but they agree that different people (e.g., CISO) must be informed.

Directives found in community playbooks include, e.g., violating SLAs (188 steps) and notifying public relations.

More people imply more tasks and coordination. Depending on the organization, one or more security teams are involved in incident response. Most participants state that they have incident response and other teams (e.g., IT operations, red team, threat intelligence, human resources) work together. Communication and the chain-of-command are relevant prerequisites as organizations *"do shift operations, on-call duty, and follow the sun for incident response." (P9)* In favor of fast operations, organizations opt for specialization so tasks can be shared and executed in parallel. Security culture and teams influence incident response processes:

- Security culture is about management support. Influence on communication and permissions can be observed: *"Permissions and pre-authorizations are important. At times you have to act without [explicit] permission." (P2)* In general, participants mention good management support within their organization but those without face consequences (e.g., missing resources), which affect tasks. As a result, tasks cannot be performed, and security becomes a topic of personal motivation: *"Within a public institution, processes take time, and focus is on essential tasks." (P5)*
- In multi-national organizations when specialists and different teams work on incidents, additional tasks cover forensic investigations, dark web searches and CTI sharing: *"We diligently share information, insert data in MISP, and correlate incidents." (P4)* Among the interview participants we notice different operation modes such as double incident assignments, task rotation, or feedback loops and different team structures. While in one organization certain tasks are performed by the incident response team itself, in other organizations these are handled by CTI, SOC/monitoring, or other dedicated teams: *"We need to involve the email team [in the case of account compromise]." (P3)*

Inside community playbooks, we find analysts-in-the-loop (e.g., ChatOps) deciding about critical process branches, reviewing machine-generated output, and conducting complex tasks (e.g., investigate and remediate).

On the shoulders of technology. Technology is a broad category influencing incident response processes and playbooks in various ways. Consequences range from general applicability (i.e., a process or playbook is relevant to the organization) to which specific actions can be taken (e.g., query EDR agents on every endpoint). Overall, influence is dependent on existing technology and its characteristics (e.g., centralized vs. decentralized, homogeneous vs. heterogeneous). Some participants point out that they only advise and coordinate actions because they do not (directly) operate the IT infrastructure: *"Business units or third parties operate our infrastructure. We advise and coordinate measures." (P6)* Technology being used to fulfill business and security requirements has the following implications:

- IT infrastructure and sourcing strategies play an essential role. Nowadays, web services are typically hosted externally: *"If necessary, we will integrate third parties (AWS, Microsoft) into our process. They will be notified by email but not via incident tracking." (P9)* Participants further mention that organizations can realize more streamlined processes if they have all their services in the cloud using one cloud provider. In contrast, OT networks and production systems are more diverse, demanding different measures.
- Organizations strive for redundant and independent incident response infrastructure: *"Semi-self-sufficient operation is possible. We cover cases when no domain controller is available. The CERT should still be functioning and able to access their workstations." (P8)*

Authorized licensed use limited to: IEEE Xplore. Downloaded on November 14,2026 at 05:10:50 UTC from IEEE Xplore. Restrictions apply.

This implies that processes cover switching to alternative infrastructure which includes communication channels (e.g., email, Mattermost, or war rooms). In addition, security tools shape what is done. Although most participants use commercial SOAR platforms, some have different solutions: *"Without a [SIEM/-SOAR] dashboard, we rely on [administration] tools to detect and respond to incidents." (P5)*

Technology drives community playbooks in communications (e.g., MS Teams or Slack), collaborations (e.g., war rooms), and security operations. SOAR platforms are primarily responsible for logic, utility, and ticketing while investigation and countermeasures rely on different tools.

7. Discussion

We discuss our research implications along the dimensions of community playbook *data quality*, influencing factors forming a *common language* to discuss different playbook perspectives, and the question of *technology assistance*. Our actionable insights emphasize how to cope with terminology, playbook content and handling playbooks.

7.1. How to talk about playbooks

Although organizations use playbooks, *what is a playbook to you?* must remain a key question due to ambiguous definitions. Toward a detailed understanding of playbooks offered by a given community or used within a given organizational context, our analysis recommends the following:

- Clarify playbook representation and implementation.
- Clarify abstraction levels and management instruments.

When it comes to community playbooks, it is best to pay attention whether or not they are code-based and linked to a SOAR platform. Emphasized by our community playbook analysis, these playbooks typically rely on additional plugins (e.g., Docker containers, APIs, or other software artifacts) offered by the SOAR platform integrating (external) services and functions. Therefore, community playbooks abstract technical measures to some extent and largely do not contain specific CLI commands or code snippets. Community playbooks need to be checked for technical content and overarching concepts (e.g., use cases) to grasp the meaning of the term playbook.

When it comes to organization-specific playbooks, it is necessary to account for other organizational management instruments. Thereby, policies, plans, checklists, and security tools can define different abstraction levels and guide processes. Broadly speaking, playbooks can tilt toward text-based instructions within a knowledge base (e.g., wiki) or toward dedicated automation scripts both being possibly referred to as playbooks. Thus, it is necessary to inquire management instruments and tools. Additionally, a separation in response and detection playbooks should be checked.

7.2. How to define playbook information

Playbooks should be precise and contain information to fulfill their intended purpose. Analyzing community playbooks and manually labeling workflow steps, we discover that basic information on who is performing an action on an object (i.e., actuator, action, artifact), as mentioned in [27], is difficult to extract, obstructing comparison and perhaps use. Thus, we see potential for standardization, including naming conventions. While we initially agreed with research findings in [18] that (executable) commands are required inside a playbook, this is opposite to how organizations see their playbooks and community playbooks look like. Instead, most organizations aim for abstract playbooks and introduce another tool-based implementation layer below.

Nevertheless, organizations show intrinsic ambiguities in the way they define their playbooks. Even without clear statistical significance, we believe that there is merit in discussing influencing factors on incident response processes and playbooks as they can offer a common language. As community playbooks cannot be used outright due to missing or obsolete information (e.g., logic, tools, ticketing), transformation according to organizational context and consideration of influencing factors is needed. Providing an initially stepping stone for theory building, we want to emphasize three insights.

First, there is no clear picture on influencing factors. In our online study, most participants believe technology exerts influence, and they have steps based on (security) technology. In our interviews, participants show a deep knowledge but are not fully aware of what shapes their playbooks, possibly explaining the absence of some factors. Despite multiple participants claiming that incident response is solely about technical matters, their responses indicate otherwise. In line with other works on security management [44], [45], we argue that interfaces to other teams and technology are the most important factors. Acknowledging challenges on boundaries, organizations should define the scope of incident response and its playbooks.

Second, as community playbooks partially contain organization-specific information, we hypothesize that organizations prefer adapting available playbooks to building them from scratch. In [18], playbook frameworks guide playbook design. Intending to make intuitive influencing factors visible, we showcase an additional path to playbook design, assisting organizations in adapting community playbooks. Consequently, this might reduce the time and resources required to build organization-specific playbooks while including all essential elements.

Third, what should be inside an organizational playbook must be squared with organizations' intend. Organizations might opt for creativity and critical thinking of their incident handlers, avoiding specifics. In contrast to behavioral research emphasizing bias and unwanted variability (noise) [46], [47], [48], we reason that some threats (APTs) demand flexibility and that more specific playbooks could introduce further challenges (e.g., prioritization, reusability, hierarchies). Nevertheless, playbooks can detail when and which

Authorized licensed use limited to: IEEE Xplore. Downloaded on November 14,2026 at 05:10:50 UTC from IEEE Xplore. Restrictions apply.

decision to make, thus building a cornerstone to combat bias, ensure consistency, and speed up repetitive tasks.

7.3. How to use, maintain, and share playbooks

For organizations using playbooks, the next step involves automation, tool selection, and deployment. However, it is crucial to determine if automation does help or harm. Interviewees mention that security professionals must be kept in the loop when making decisions. Besides automation and seen in the online study, playbooks can also aid documentation, reporting, and onboarding thereby improving existing processes. Ideally, building organization-specific playbooks is based on systematically merging community playbooks and influencing factors. Here, it is on future research to address recent developments of generative artificial intelligence for incident response (e.g., Microsoft Security Copilot's promptbook), investigating options to build highly contextual playbooks automatically. For playbook maintenance, organizations need to recognize and keep track of changes. Influencing factors could be kept in a dedicated repository and frequently checked. With separated repositories, organizations can build their organization-specific playbooks on-the-fly coping with a growing number of threats and playbooks over time. Playbook sharing is the foundation toward establishing a common language for incident response. In few years, with even more playbook data available, causal effects and the meaning of data (i.e., a high/low number of steps) can be explored. We see challenges in diverse or new data formats and different sharing modes (e.g., internal recipients wish for commands) to be addressed in the future.

8. Related Work

The idea of structured guidance achieved with playbooks is present in adjacent research areas. We first mention related work on incident response playbooks before discussing system hardening, vulnerability handling, IT operations, and business processes on which playbooks are based.

8.1. Incident response playbooks

Incident response playbooks caught researchers' interest. Closest to our work, Stevens et al. [18] investigated playbook design pointing to organizational constraints. Schlette et al. [27] compared structured playbook representations building a prerequisite to playbook sharing. In [26] the removal of confidential information is briefly discussed. Similar to how playbooks provide strategic guidance in sports, their use in fighting DDoS attacks and establishing incident response programs centers on outlining different options [19], [25]. In cybersecurity, playbooks can be seen as a continuation of threat intelligence research aiming to present and disseminate actionable security information [32], [49], [50]. We find security standardization efforts encompassing playbooks and courses of action [29], [31], [51]. Aside from academic research, two GitHub repositories aggregate information on incident response [52], [53].

8.2. Structured guidance and systematic processes

Organizations perform system hardening to reduce their attack surface with securely configured systems [9], [10]. System hardening and security configuration rely on best practices and their technical implementation relates to playbooks. What must be done to conform with a given security baseline is defined by vendors (e.g., Microsoft security baselines [54]), community organizations (e.g., Center for Internet Security, CIS Benchmarks [55]), and governmental institutions (e.g., US Department of Defense Security Technical Implementation Guides, DoD STIGs [56]). Typically, as part of the Security Content Automation Protocol (SCAP), XCCDF-structured security checklists are used. They contain rules, fixes and can link to OVAL-based vulnerability checks. Implementation is based on tools (e.g., Ansible, Chef, Terraform), dedicated scripts (e.g., PowerShell, bash), and other configuration options (e.g., GPO backups). We notice similarities (e.g., abstraction, tools) and differences (e.g., proactive) compared to incident response playbooks.

Once vulnerabilities have been discovered and disclosed [14], organizational vulnerability handling involves preventing exploitation by following security advisories and patching systems [11], [12], [13], [57]. Typically, organizations are guided by CVRF/CSAF-structured security advisories describing how to fix a vulnerability [58]. We note that incident response playbooks focus on organizational processes and thus go beyond the rich stream of vulnerability research.

Extending the scope to non-security areas, IT operations, system administration, and configuration management cover systematic deployment, maintenance, and monitoring [59], [60]. Consequently, regular tasks are structured and automated with scripts or runbooks to ensure consistency [61]. Automation relies heavily on tools, with Ansible and its playbooks being a prominent example [17], [62]. In cloud environments, playbook-like concepts are part of *Infrastructure as Code* [63] but also remain security agnostic.

8.3. Business process orchestration

Process orchestration and automation are tightly coupled with SOAR platforms but are rooted in business process research [15], [64]. Business processes and process orchestration are necessary when there are multiple activities and diversity in people, processes, and technology [65], [66]. Business Process Management Systems (BPMS) define execution engines and perform fundamental tasks, such as modeling, simulating, instantiating, and monitoring workflows (i.e., automated business processes) [67], [68]. Besides, business process re-engineering relates to influencing factors and targets "order-of-magnitude improvements" [37], [38], [69]. Dedicated software solutions (e.g., Camunda, ServiceNow) implement execution engines and automation platforms for business processes. Comparing architectures and functionalities, we note that SOAR platforms and security orchestration largely borrow from business process research but instantiate concepts within the security context. A notable difference is the deep integration of security tools.

Authorized licensed use limited to: IEEE Xplore. Downloaded on November 14,2026 at 05:10:50 UTC from IEEE Xplore. Restrictions apply.

9. Conclusion

In brief, we investigated incident response playbooks and different factors that influence and shape their sharing, maintenance, and use. Actionable insights on data quality, common language, and technology assistance document necessary considerations for playbooks. Our initial belief that playbooks have a clear and concise definition was challenged as we discovered that individuals have different understandings of what constitutes a playbook. Besides, organizations intentionally keep playbook information abstract to support flexibility and reuse, which is partially reflected in community playbooks. Although our research does not statistically clarify the factors' relevance, it makes factors visible, guiding playbook design and use with a common language. We observe that organizations do play it by the books but adjust playbooks to their context. Our findings suggest that technology and the security team(s) are critical drivers in shaping incident response playbooks. For future work, we see opportunities to explore the systematic merging of community playbooks and influencing factors to build organization-specific playbooks. The emergence of generative artificial intelligence has already begun to reshape incident response processes, and we are keen to observe how playbooks and their use will continue to evolve in the future.

Acknowledgment

The authors would like to sincerely thank all interviewees and study participants for their invaluable insights and time spent, without which this research would not have been possible. This work was supported by the German Federal Ministry of Education and Research (BMBF) as part of the DEVISE project and by the European Union's Horizon 2020 research and innovation program under Grant Agreement No. 830927.

References

[1] ISO/IEC, "ISO/IEC 27001:2022 - Information security, cybersecurity and privacy protection — Information security management systems — Requirements," International Organization for Standardization, Tech. Rep., 2022.

[2] Executive Office of the President, "Executive Order 14028 of May 12, 2021 – Improving the Nation's Cybersecurity," 2021, last accessed 2023-03-01. [Online]. Available: https://www.whitehouse.gov/briefing-room/presidential-actions/2021/05/12/executive-order-on-improving-the-nations-cybersecurity/

[3] P. Cichonski, T. Millar, T. Grance, K. Scarfone *et al.*, "Computer Security Incident Handling Guide," National Institute of Standards and Technology (NIST), Tech. Rep. SP 800-61, Rev2, 2012.

[4] M. J. West-Brown, D. Stikvoort, K.-P. Kossakowski, G. Killcrece, and R. Ruefle, "Handbook for Computer Security Incident Response Teams (CSIRTs)," Carnegie-Mellon Software Engineering Institute, Tech. Rep., 2003.

[5] $(ISC)^2$, "$(ISC)^2$ Cybersecurity Workforce Study 2022," $(ISC)^2$, Tech. Rep., 2022.

[6] J. Dykstra and C. L. Paul, "Cyber Operations Stress Survey (COSS): Studying fatigue, frustration, and cognitive workload in cybersecurity operations," in *11th USENIX Workshop on Cyber Security Experimentation and Test (CSET 18)*, 2018.

[7] R. Brown and P. Stirparo, "SANS 2022 Cyber Threat Intelligence Survey," SANS, Tech. Rep., 2022.

[8] C. Crowley and B. Filkins, "SANS 2022 SOC Survey," SANS, Tech. Rep., 2022.

[9] K. Scarfone, W. Jansen, and T. Miles, "Guide to General Server Security," National Institute of Standards and Technology (NIST), Tech. Rep. SP 800-123, 2008.

[10] J. Christensen, I. M. Anghel, R. Taglang, M. Chiroiu, and R. Sion, "DECAF: Automatic, Adaptive De-bloating and Hardening of COTS Firmware," in *29th USENIX Security Symposium, USENIX Security 2020, August 12-14, 2020*, 2020, pp. 1713–1730.

[11] S. de Smale, R. van Dijk, X. Bouwman, J. van der Ham, and M. van Eeten, "No One Drinks From the Firehose: How Organizations Filter and Prioritize Vulnerability Information," in *2023 IEEE Symposium on Security and Privacy, SP 2023, Proceedings, 22-25 May, 2023, San Francisco, California, USA*, 2023.

[12] N. Alomar, P. Wijesekera, E. Qiu, and S. Egelman, ""You've Got Your Nice List of Bugs, Now What?" Vulnerability Discovery and Management Processes in the Wild," in *Sixteenth Symposium on Usable Privacy and Security, SOUPS 2020, August 7-11, 2020*, 2020, pp. 319–339.

[13] K. A. Farris, A. Shah, G. Cybenko, R. Ganesan, and S. Jajodia, "VULCON: A System for Vulnerability Prioritization, Mitigation, and Management," *ACM Transactions on Privacy and Security (TOPS)*, vol. 21, no. 4, pp. 16:1–16:28, 2018.

[14] D. Votipka, R. Stevens, E. M. Redmiles, J. Hu, and M. L. Mazurek, "Hackers vs. Testers: A Comparison of Software Vulnerability Discovery Processes," in *2018 IEEE Symposium on Security and Privacy, SP 2018, Proceedings, 21-23 May 2018, San Francisco, California, USA*, 2018, pp. 374–391.

[15] M. Dumas, M. L. Rosa, J. Mendling, and H. A. Reijers, *Fundamentals of Business Process Management*. Springer, 2013.

[16] K. Salimifard and M. Wright, "Petri net-based modelling of workflow systems: An overview," *European Journal of Operational Research*, vol. 134, no. 3, pp. 664–676, 2001.

[17] Red Hat, "Using Ansible playbooks," 2023, last accessed 2023-03-01. [Online]. Available: https://docs.ansible.com/ansible/latest/playbook_guide/index.html

[18] R. Stevens, D. Votipka, J. Dykstra, F. Tomlinson, E. Quartararo, C. Ahern, and M. L. Mazurek, "How Ready is Your Ready? Assessing the Usability of Incident Response Playbook Frameworks," in *CHI Conference on Human Factors in Computing Systems*, 2022, pp. 1–18.

[19] J. Bollinger, B. Enright, and M. Valites, *Crafting the InfoSec playbook: security monitoring and incident response master plan*. O'Reilly Media, Inc., 2015.

[20] I. Lella, E. Tsekmezoglou, R. S. Naydenov, C. Ciobanu, A. Malatras, and M. Theocharidou, "ENISA Threat Landscape 2022," European Union Agency for Network and Information Security (ENISA), Tech. Rep., 2022.

[21] C. Lawson and A. Price, "2022 Market Guide for Security Orchestration, Automation and Response Solutions," Gartner, Tech. Rep., 2022.

[22] MarketsandMarkets Research, "Security Orchestration Automation and Response (SOAR) Market Size, Share and Global Market Forecast to 2027," MarketsandMarkets, Tech. Rep., 2022.

[23] OASIS, "CACAO Security Playbooks Version 1.0 - Committee Specification 02," OASIS, Tech. Rep., 2021, last accessed 2023-03-01. [Online]. Available: https://docs.oasis-open.org/cacao/security-playbooks/v1.0/security-playbooks-v1.0.html

[24] FIRST Forum of Incident Response and Security Teams, "Automation SIG," 2023, last accessed 2023-03-01. [Online]. Available: https://www.first.org/global/sigs/automation/

Authorized licensed use limited to: IEEE Xplore. Downloaded on November 14,2026 at 05:10:50 UTC from IEEE Xplore. Restrictions apply.

[25] A. S. M. Rizvi, L. M. Bertholdo, J. M. Ceron, and J. S. Heidemann, "Anycast agility: Network playbooks to fight ddos," in *31st USENIX Security Symposium, USENIX Security 2022, Boston, MA, USA, August 10-12, 2022*, 2022, pp. 4201–4218.

[26] M. A. Gurabi, A. Mandal, J. Popanda, R. Rapp, and S. Decker, "SASP: a Semantic web-based Approach for management of Sharable cybersecurity Playbooks," in *ARES 2022: The 17th International Conference on Availability, Reliability and Security, Vienna, Austria, August 23 - 26, 2022*, 2022, pp. 109:1–109:8.

[27] D. Schlette, M. Caselli, and G. Pernul, "A Comparative Study on Cyber Threat Intelligence: The Security Incident Response Perspective," *IEEE Communications Surveys & Tutorials*, vol. 23, no. 4, pp. 2525–2556, 2021.

[28] A. Shaked, Y. Cherdantseva, and P. Burnap, "Model-Based Incident Response Playbooks," in *ARES 2022: The 17th International Conference on Availability, Reliability and Security, Vienna, Austria, August 23 - 26, 2022*, 2022, pp. 26:1–26:7.

[29] V. Mavroeidis, P. Eis, M. Zádník, M. Caselli, and B. Jordan, "On the Integration of Course of Action Playbooks into Shareable Cyber Threat Intelligence," in *2021 IEEE International Conference on Big Data (Big Data), Orlando, FL, USA, December 15-18, 2021*, 2021, pp. 2104–2108.

[30] C. Onwubiko and K. Ouazzane, "SOTER: A playbook for cybersecurity incident management," *IEEE Transactions on Engineering Management*, vol. 69, no. 6, pp. 3771–3791, 2020.

[31] A. Applebaum, S. Johnson, M. Limiero, and M. Smith, "Playbook Oriented Cyber Response," in *2018 National Cyber Summit (NCS)*. IEEE, 2018, pp. 8–15.

[32] X. Bouwman, V. L. Pochat, P. Foremski, T. van Goethem, C. H. Gañán, G. C. M. Moura, S. Tajalizadehkhoob, W. Joosen, and M. van Eeten, "Helping hands: Measuring the impact of a large threat intelligence sharing community," in *31st USENIX Security Symposium, USENIX Security 2022, Boston, MA, USA, August 10-12, 2022*, 2022, pp. 1149–1165.

[33] B. Stojkovski, G. Lenzini, V. Koenig, and S. Rivas, "What's in a Cyber Threat Intelligence sharing platform?: A mixed-methods user experience investigation of MISP," in *ACSAC '21: Annual Computer Security Applications Conference, Virtual Event, USA, December 6 - 10, 2021*, 2021, pp. 385–398.

[34] Financial Services Information Sharing and Analysis Center, "Reducing Cyber Risk Through Intelligence Sharing," 2023, last accessed 2023-03-01. [Online]. Available: https://www.fsisac.com/who-we-are

[35] H. Paananen, M. Lapke, and M. Siponen, "State of the Art in Information Security Policy Development," *Computers & Security*, vol. 88, 2020.

[36] K. J. Knapp, R. Franklin Morris, T. E. Marshall, and T. A. Byrd, "Information Security Policy: An Organizational-Level Process Model," *Computers & Security*, vol. 28, no. 7, pp. 493—508, 2009.

[37] J. vom Brocke, S. Zelt, and T. Schmiedel, "On the role of context in business process management," *International Journal of Information Management*, vol. 36, no. 3, pp. 486–495, 2016.

[38] M. Rosemann, J. Recker, and C. Flender, "Contextualisation of Business Processes," *International Journal of Business Process Integration and Management*, vol. 3, no. 1, pp. 47–60, 2008.

[39] G. B. Willis and P. Royston, *Cognitive Interviewing: A Tool for Improving Questionnaire Design*. SAGE Publications, Inc., 2005.

[40] V. Braun and V. Clarke, "Using thematic analysis in psychology," *Qualitative Research in Psychology*, vol. 3, no. 2, pp. 77–101, 2006.

[41] D. S. Cruzes and T. Dybå, "Research synthesis in software engineering: A tertiary study," *Information and Software Technology*, vol. 53, no. 5, pp. 440–455, 2011.

[42] V. Braun and V. Clarke, *Thematic Analysis: A Practical Guide*. London, UK: SAGE Publications, Ltd., 2019.

[43] Object Management Group (OMG), "Business Process Model and Notation (BPMN) Specification Version 2.0.2," OMG, Tech. Rep., 2013, last accessed 2023-03-01. [Online]. Available: https://www.omg.org/spec/BPMN/2.0.2/PDF

[44] D. Ashenden, "Information Security management: A human challenge?" *Information security technical report*, vol. 13, no. 4, pp. 195–201, 2008.

[45] G. D. Bhatt, "Knowledge management in organizations: examining the interaction between technologies, techniques, and people," *Journal of knowledge management*, 2001.

[46] B. Flyvbjerg, "Top ten behavioral biases in project management: An overview," *Project Management Journal*, vol. 52, no. 6, pp. 531–546, 2021.

[47] T. D. Wilson and N. Brekke, "Mental contamination and mental correction: unwanted influences on judgments and evaluations," *Psychological bulletin*, vol. 116, no. 1, pp. 117–142, 1994.

[48] D. Kahneman and A. Tversky, "Intuitive prediction: Biases and corrective procedures," Decisions and Designs Inc, Tech. Rep., 1977.

[49] W. Tounsi and H. Rais, "A survey on technical threat intelligence in the age of sophisticated cyber attacks," *Computers & Security*, vol. 72, pp. 212–233, 2018.

[50] F. Skopik, G. Settanni, and R. Fiedler, "A problem shared is a problem halved: A survey on the dimensions of collective cyber defense through security information sharing," *Computers & Security*, vol. 60, pp. 154–176, 2016.

[51] S. Barnum, "Standardizing Cyber Threat Intelligence Information with the Structured Threat Information eXpression (STIX)," MITRE Corporation, Tech. Rep., 2012.

[52] M. Wahnon, "Awesome Incident Response," 2023, last accessed 2023-03-01. [Online]. Available: https://github.com/meirwah/awesome-incident-response

[53] Correlated Security, "Awesome SOAR," 2023, last accessed 2023-03-01. [Online]. Available: https://github.com/correlatedsecurity/Awesome-SOAR

[54] Microsoft Community, "Windows security baselines," 2023, last accessed 2023-03-01. [Online]. Available: https://learn.microsoft.com/en-us/windows/security/threat-protection/windows-security-configuration-framework/windows-security-baselines

[55] Center for Internet Security, "CIS Benchmarks," 2023, last accessed 2023-03-01. [Online]. Available: https://www.cisecurity.org/cis-benchmarks

[56] US Department of Defense, "Security Technical Implementation Guides (STIGs)," 2023, last accessed 2023-03-01. [Online]. Available: https://public.cyber.mil/stigs/

[57] F. Li and V. Paxson, "A large-scale empirical study of security patches," in *Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security*, 2017, pp. 2201–2215.

[58] OASIS, "Common Security Advisory Framework Version 2.0 OASIS Standard," OASIS, Tech. Rep., 2022, last accessed 2022-03-01. [Online]. Available: https://docs.oasis-open.org/csaf/csaf/v2.0/csaf-v2.0.html

[59] A. Frisch, *Essential system administration: Tools and techniques for linux and unix administration*. O'Reilly Media, Inc., 2002.

[60] E. Nemeth, G. Snyder, T. R. Hein, B. Whaley, and D. Mackin, *UNIX and Linux system administration handbook*. Pearson Education, 2018.

[61] M. C. Langston, *Short Topics in Systems Administration - Documentation Writing for System Administrators*. USENIX/SAGE, 2003.

[62] L. Hochstein and R. Moser, *Ansible: Up and Running: Automating configuration management and deployment the easy way*. O'Reilly Media, Inc., 2017.

Authorized licensed use limited to: IEEE Xplore. Downloaded on November 14,2026 at 05:10:50 UTC from IEEE Xplore. Restrictions apply.

[63] K. Morris, *Infrastructure as code*. O'Reilly Media, Inc., 2020.

[64] W. M. P. van der Aalst, "The Application of Petri Nets to Workflow Management," *Journal of Circuits, Systems, and Computers*, vol. 8, no. 1, pp. 21–66, 1998.

[65] M. Weske, "Process Orchestrations," in *Business Process Management: Concepts, Languages, Architectures*. Springer, 2019, pp. 123–240.

[66] Camunda, "The Process Orchestration Handbook," 2021, last accessed 2023-03-01. [Online]. Available: https://camunda.com/process-orchestration/

[67] A. Oberweis, "An integrated approach for the specification of processes and related complex structured objects in business applications," *Decision Support Systems*, vol. 17, no. 1, pp. 31–53, 1996.

[68] D. Georgakopoulos, M. F. Hornick, and A. P. Sheth, "An Overview of Workflow Management: From Process Modeling to Workflow Automation Infrastructure," *Distributed Parallel Databases*, vol. 3, no. 2, pp. 119–153, 1995.

[69] P. O'Neill and A. S. Sohal, "Business Process Reengineering A review of recent literature," *Technovation*, vol. 19, no. 9, pp. 571–581, 1999.

[70] OASIS, "Open Command and Control (OpenC2) Language Specification Version 1.0 - Committee Specification 02," OASIS, Tech. Rep., 2019, last accessed 2023-03-01. [Online]. Available: https://docs.oasis-open.org/openc2/oc2ls/v1.0/oc2ls-v1.0.html

Appendix A.
Graphical phishing playbook

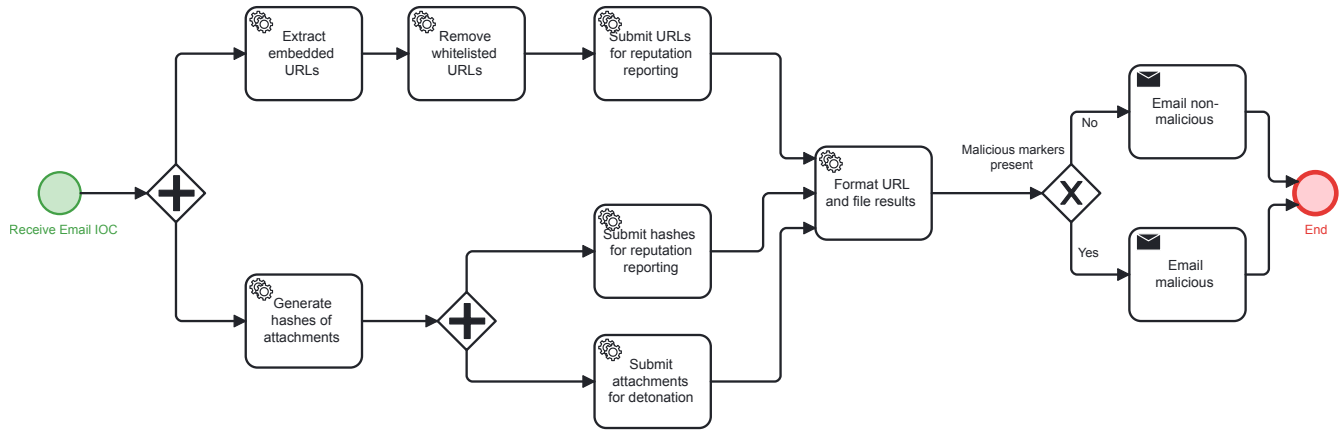


Figure 5. Graphical phishing playbook with BPMN (source: IACD).

Appendix B.
Code-based phishing playbook workflow step (excerpt)

```
{
  "action": "URL reputation",
  "action_type": "investigate",
  "assets": [
    {
      "app_name": "VirusTotal",
      "app_version": "1.2.40",
      "output": [
        {
          "data_path": "action_result.status"
        },
        {
          "data_path": "action_result.parameter.url"
        },
        {
          "data_path": "action_result.data.*.resource"
        },
        {
          "data_path": "action_result.data.*.scan_date"
        },
        {
          "data_path": "action_result.data.*.scan_id"
        },
        {
          "data_path": "action_result.data.*.url"
        },
        {
          "data_path": "action_result.message"
        }
      ],
      "parameters": {
        "url": {
          "data_type": "string",
          "description": "URL to query",
          "key": "url",
          "required": true
        }
      }
    }
  ]
}
```

Figure 6. Excerpt of a workflow step investigating URL reputation within a code-based phishing playbook (source: Splunk SOAR).

Authorized licensed use limited to: IEEE Xplore. Downloaded on November 14,2026 at 05:10:50 UTC from IEEE Xplore. Restrictions apply.

Appendix C.
Playbook terminology

TABLE 7. SECURITY STANDARDS AND PROCESS NOTATIONS HELP TO UNDERSTAND PLAYBOOK TERMINOLOGY.

Term	Description	CACAO [23]	OpenC2 [70]	CSAF [58]	BPMN [43]
Playbook	A playbook describes a specific cybersecurity process or procedure based on a workflow with individual steps or actions. Playbooks also include metadata. (Example: Phishing playbook)	**Playbook:** "[. . .] a playbook consisting of one or more security actions combined into a sequence or algorithmically-defined use." "A **template playbook** will not be immediately executable by a receiving organization but may inform their own executable playbook for their specific environment or organization."	N/A	**CSAF document:** "security advisory text document [. . .]." **Advisory:** "reporting item that describes a condition present in an artifact and that requires action by the consumers."	**BPMN Model / BPMN Diagram:** "[. . .] a BPMN diagram is a particular snapshot of a BPMN model at a certain point in time."
Workflow and Workflow Step	A workflow or course of action captures multiple workflow steps and procedural logic. A workflow step is defined by its position and its structural components. (Example: Start - 1) Step X, 2) Step Y, 3) Step Z - End)	"**Workflows** contain a series of **steps** [. . .]. Workflows process steps either sequentially, in parallel, or both depending on the type of steps required by the playbook."	**OpenC2 Command:** "The Command describes an Action to be performed on a Target and may include information identifying the Actuator or Actuators that are to execute the Command." **Command** $\approx$ workflow step	**Remediations:** "Every Remediation item [. . .] specifies details on how to handle (and presumably, fix) a vulnerability." **Remediations - Details:** "[. . .] contains a thorough human-readable discussion of the remediation."	**Business Process:** "A defined set of business activities that represent the steps required to achieve a business objective. It includes the flow and use of information and resources." **Activity:** "Work that a company or organization performs using business processes. An activity can be atomic or non-atomic (compound)."
Actuator	An actuator represents an entity performing an action. Information systems, applications, or humans are actuators and provide specific capabilities. (Example: Incident handler / linux server)	**Targets:** "The CACAO target object contains detailed information about the entities or devices that accept, receive, process, or execute one or more commands as defined in a workflow step. Targets contain the information needed to send commands as defined in steps to devices or humans" (e.g., individual, ssh, http-api, net-address).	**Actuator:** "The Actuator executes the Command. The Actuator will be defined within the context of an Actuator Profile" (e.g., Stateless Paket Filtering Profile/-function).	N/A	**Pool:** "A Pool represents a Participant in a Collaboration." **Lane:** "A partition that is used to organize and categorize activities within a Pool. [. . .] Lanes are often used for such things as internal roles (e.g., Manager, Associate), systems (e.g., an enterprise application), or an internal department (e.g., shipping, finance)."
Action	An action is an executable instruction or task representing a precise cybersecurity measure. Actions are manifold but center on operations towards systems, networks, or humans. (Example: Investigate / block)	**Action:** "[. . .] security activity in an organization [. . .]. Those actions may represent an activity to investigate, prevent, mitigate or remediate a specific security state that has either occurred or the organization is taking action to ensure the security state never occurs." **Commands:** "The CACAO command object [. . .] contains detailed information about the commands that are to be executed or processed automatically or manually as part of a workflow step" (e.g., last; netstat -n; ls -l -a /root or Disconnect the machine from the network and call the SOC on-call person).	**Action:** "The task or activity to be performed" (e.g., scan, deny).	N/A	**Task:** "An atomic activity that is included within a Process. A Task is used when the work in the Process is not broken down to a finer level of Process Model detail. Generally, an end-user, an application, or both will perform the Task."
Artifact	An artifact serves as the object or input of an action. Artifacts allow identification and refer to threat intelligence. (Example: IP address)	"**Variables** can be defined and used as the playbook is executed" (e.g., $$ipv4-addr, $$sha256-hash). **in_args:** "The optional list of arguments passed to the target(s) as input to the step." **Variables and in_args** $\approx$ artifact	**Target:** "The object of the action. The Action is performed on the Target" (e.g., ipv4_net, device, file, mac_addr).	N/A (related to **Vulnerabilities Property - Remediations - Group Ids** and **Vulnerabilities Property - Remediations - Product Ids** "[. . .] the current remediation item applies to.")	**Data Objects:** "The primary construct for modeling data within the Process flow is the DataObject element. A DataObject has a well-defined lifecycle, with resulting access constraints." **Data Inputs:** "Data requirements are captured as Data Inputs [. . .]."
Output	An output is the result of a workflow step. Outputs are optional and can contain status codes or other data. (Example: Success)	**out_args:** "The optional list of arguments that are returned from this step after execution of the commands by the targets."	**OpenC2 Response:** "The Response is a Message sent from the recipient of a Command. Response messages provide acknowledgment, status, results from a query, or other information."	N/A	**Data Objects:** "The primary construct for modeling data within the Process flow is the DataObject element. A DataObject has a well-defined lifecycle, with resulting access constraints." **Data Outputs:** "Data that is produced is captured using Data Outputs [. . .]."

Authorized licensed use limited to: IEEE Xplore. Downloaded on November 14,2026 at 05:10:50 UTC from IEEE Xplore. Restrictions apply.

Appendix D.
Multi-category playbooks

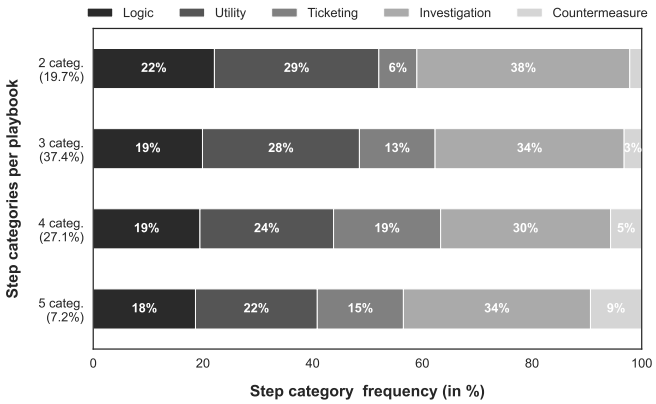


Figure 4. Multi-category playbooks and their workflow step composition.

Appendix E.
Interview codebook

The codebook matches interview questions to external and internal influencing factors. Most factors relate to the three incident scenarios (i.e., Ransomware, DDoS, APT) and are addressed by "what-if" questions. In addition, we used the overarching questions for each scenario. The overarching questions provided in-depth results emphasizing the relevance of individual factors.

Overarching Questions:

- How does your organization handle a [incident type] scenario?
- How does your organization handle this scenario differently than other organizations?

External Factor 1: *Attacker characteristics (motivation, behavior, location)*
What would your organization do differently if ...

- it is operating in Israel/Ukraine?
- it assumes a state-sponsored attacker group located in Iran/Russia behind the attack?
- it has specified incident response time limits for APT attacks to 1 month?

External Factor 2: *Industry standards and guidelines (including frameworks)*
Does your organization use ...

- generic security process descriptions (e.g., BPMN, NIST Incident Response Life Cycle, NIST Cybersecurity Framework, FIRST CSIRT Framework, etc.)?
- incident response maturity models (e.g., SIM3, etc.)?
- incident response standards (e.g., CACAO, OpenC2, RE&CT, MITRE D3FEND, etc.)?
- an incident response policy to define guiding principles?

External Factor 3: *Laws and regulations (business structure, location/privacy, sector)*
What would your organization do differently if ...

- it is a publicly traded company in the United States?
- it has customers in the European Union?
- it is a sub-contractor for the defense industry?

External Factor 4: *Supply chain and business partners expectations*
What would your organization do differently if ...

- it has sourced server hosting to a third party?
- it is a sub-contractor for the defense industry?
- it observed compromised email accounts?

Internal Factor 1: *Incident response directives (data operations, attack targets/assets)*
What would your organization do differently if ...

- it has proxy log retention set to 1 week?
- it has business-critical applications running on the targeted web server?
- it has defined formal reporting requirements?
- its CFO's laptop is affected?

Internal Factor 2: *People (security culture/mandate, security team)*
What would your organization do differently if ...

- it has a dedicated Cyber Threat Intelligence team?
- it has defined email for incident response communication?
- it has a security team with 100 security experts?
- it has specified to contact the CISO, but the CISO is unavailable?

Internal Factor 3: *Technology (infrastructure/tech stack, security tools)*
What would your organization do differently if ...

- it defined an incident budget of $100k?
- it has sourced server hosting to a third party?
- it has a Web Application Firewall and additional server capacity?

Does your organization use ...

- Security Orchestration, Automation and Response (SOAR) tools (e.g., Splunk Phantom, Cortex XSOAR, Tines, etc.)?

Authorized licensed use limited to: IEEE Xplore. Downloaded on November 14,2026 at 05:10:50 UTC from IEEE Xplore. Restrictions apply.

Appendix F.
Meta-Review

F.1. Summary

This paper explores the content of publicly-shared community incident response playbooks and the factors influencing playbook customization and deployment. Through a multi-step experiment involving a measurement study, online survey, and interviews with security professionals, the authors find that organizations customize their playbooks based on their own definitions and areas of incident response.

F.2. Scientific Contribution

- Provides a New Data Set For Public Use
- Provides a Valuable Step Forward in an Established Field

F.3. Reasons for Acceptance

1) The paper curates a set of playbooks and conducts a structured analysis, making an important step in the study of playbooks. The inclusion of interviews with various actors adds value to the research. While some findings were considered expected, the mention of counter-intuitive results, such as "Attacker behavior and motivation beat location", was appreciated by reviewers.
2) The paper highlights failed approaches, explains why they likely failed, and describes the restrictions of the selected alternative approach. This practice was appreciated as it promotes future replication or related research by providing insights into what works and what doesn't.
3) The authors provide a GitHub repository containing the playbook data, research artifacts, and the questionnaire and interview guide. Reviews mentioned transparency and their increased confidence in the technical accuracy of the work.

F.4. Noteworthy Concerns

Insufficient findings and actionable insight: Reviews expressed dissatisfaction with the lack of concrete insights and absence of specific evidence supporting key claims. Reviewers emphasized the need for clearer insights and practical implications for researchers and practitioners based on the study's findings. It was also suggested that future studies may benefit from building upon the data presented in the paper to generate more meaningful insights and practical implications.

Appendix G.
Response to the Meta-Review

We thank the reviewers and our shepherd for the time and effort spent reviewing our manuscript and for the fair and positive feedback. By sharing our compiled playbook dataset, committing to keep it public on GitHub, and writing this paper on playbook characteristics and influencing factors, we wanted to contribute to the academic understanding of a topic comprehensively known only by practitioners and further promote research in the cybersecurity incident response field. Our aim was to provide a solid scientific foundation on the use of playbooks and to position our paper as a strong groundwork on top of which future research can build on (or even challenge) our findings. What follows provides some details on how we addressed the main concern from the meta-review:

G.1. Main concern

We acknowledge that our findings may not be definitive in all their aspects. However, we believe they offer valuable insights that can guide future research on playbooks. We understand the reviewers' concerns regarding the lack of actionable insights and specific evidence supporting our key claims. To rectify this, we consolidated and expanded upon the insights derived from our research, providing clearer and more tangible implications for both researchers and practitioners. More specifically:

- The actionable insights under review were: addressing data quality issues, identifying technological assistance opportunities, and establishing a common language for discussing incident response playbooks. To ensure greater clarity, we have expounded on such insights and findings, which are now highlighted in the discussion and conclusion sections of the paper.
- To further substantiate our claims, we included additional information where deemed necessary by the reviewers. For instance, we have supplemented Section 4 (RQ1) with incident-specific playbook information. Moreover, our research connects three distinct data sets, facilitating in-depth discussions on influencing factors and playbook content. While RQ1 focuses on community playbooks, RQ2 delves into the influencing factors that determine organization-specific playbooks. We recognize that the connection between the research questions might not have been perfect, but by incorporating examples (e.g., location look-up, SLAs, communication tools) from RQ1, we better corroborate or challenge interviewees' perceptions of influencing factors.

Authorized licensed use limited to: IEEE Xplore. Downloaded on November 14,2026 at 05:10:50 UTC from IEEE Xplore. Restrictions apply.